

Проект по оценке уязвимостей

Автоматизированное сканирование уязвимостей с помощью Tenable Nessus Essentials

Инструмент: Tenable Nessus Essentials

Целевая система: Metasploitable 2

Среда: Kali Linux + Oracle VirtualBox

Метод: Basic Network Scan

Направление: Cybersecurity,
Vulnerability Management

Автор: Соколов Руслан
Младший Специалист по
анализу защищенности

Октябрь 2026

Содержание

1 описание лабораторной среды и скоупа	3ст
1.1.контекст целевой машины	3ст
1.2. Сетевая изоляция среды	3ст
1.3 методология и настройка tenable nessus	3ст
2 краткое резюме результатов	4ст
3 глубокий анализ ключевых срабатываний плагинов	6ст
3.1. Срабатывание плагинов nessus (проблемы криптографии ssl/tls).	6ст
3.2. Срабатывание плагинов по критическим дефектам ос (системные бэкдоры)	7ст
4 программа исправлений на основе рекомендаций nessus	8ст
Заключение	8ст

1 ОПИСАНИЕ ЛАБОРАТОРНОЙ СРЕДЫ И СКОУПА (SCOPE & ENVIRONMENT)

1.1. Контекст целевой машины

Объектом исследования выступает операционная система **Metasploitable 2** (IP: 10.0.2.4), развернутая на базе устаревшего дистрибутива Canonical Ubuntu Linux SEoL (8.04.x). Данная система намеренно содержит критические ошибки конфигурации, устаревшие версии сетевых демонов и встроенные бэкдоры. Цель проекта — протестировать эффективность сканера корпоративного уровня Tenable Nessus в обнаружении скрытых и явных угроз.

1.2. Сетевая изоляция среды

Для безопасного развертывания стенда в гипервизоре Oracle VirtualBox была спроектирована изолированная кибер-песочница:

- **Сетевой режим:** Сеть NAT, подсеть 10.0.2.0/24.
- **Атакующий узел:** Kali Linux, выступающий в роли хоста для сканера Nessus.
- **Безопасность хоста:** Функция перенаправления портов на физический компьютер принудительно отключена. Это полностью изолировало уязвимый сервер от реальной домашней сети, сохранив при этом внутреннюю связь между Kali и Metasploitable.

1.3 методология и настройка tenable nessus

Анализ защищенности проводился строго с использованием функционала **Tenable Nessus Essentials**:

1. **Развертывание ПО:** Сканер был развернут внутри Kali Linux
2. **Конфигурация сканирования:** Был выбран официальный шаблон **Basic Network Scan**.
3. **Обработка данных:** Все найденные уязвимости автоматически сопоставлялись с международной метрикой рисков **CVSS v3.0** (Common Vulnerability Scoring System).

2 КРАТКОЕ РЕЗЮМЕ РЕЗУЛЬТАТОВ

По завершении процесса сканирования Nessus обнаружил 72 уязвимых элемента и 140 информационных находок. В интерфейсе Nessus результаты распределены по категориям Critical, High, Medium, Low и Mixed. Категория Mixed включает 20 результатов и не отображается на представленном графике распределения по уровням CVSS.

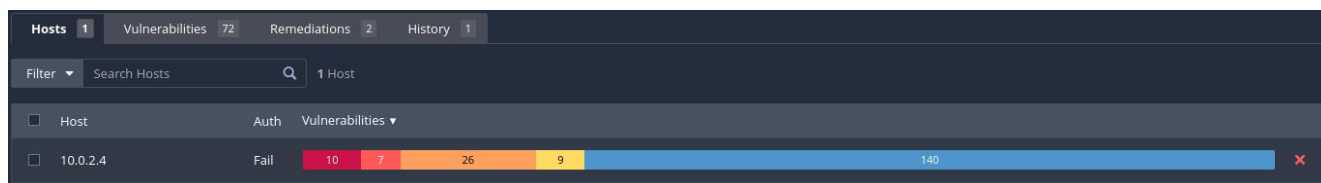


Рисунок 1 — общий краткий результат сканирования



Рисунок 2 — график результата анализа

По результатам сканирования Nessus обнаружил 72 уязвимых элемента. В интерфейсе результаты представлены по категориям Critical, High, Medium, Low и Mixed. При этом категории Critical–Low соответствуют уровням серьезности CVSS, а Mixed представляет результаты, для которых отображается смешанная/комбинированная оценка:

- **Критические (Critical):** 10
- **Высокие (High):** 7
- **Средние (Medium):** 26
- **Mixed :** 20
- **Низкие (Low):** 9
- **Информационные (Info):** 140

Подавляющее большинство критических уязвимостей связано со старыми версиями сетевых служб (веб-серверы Apache Tomcat, базы данных) и фатальными архитектурными дефектами шифрования транспортного уровня SSL/TLS.

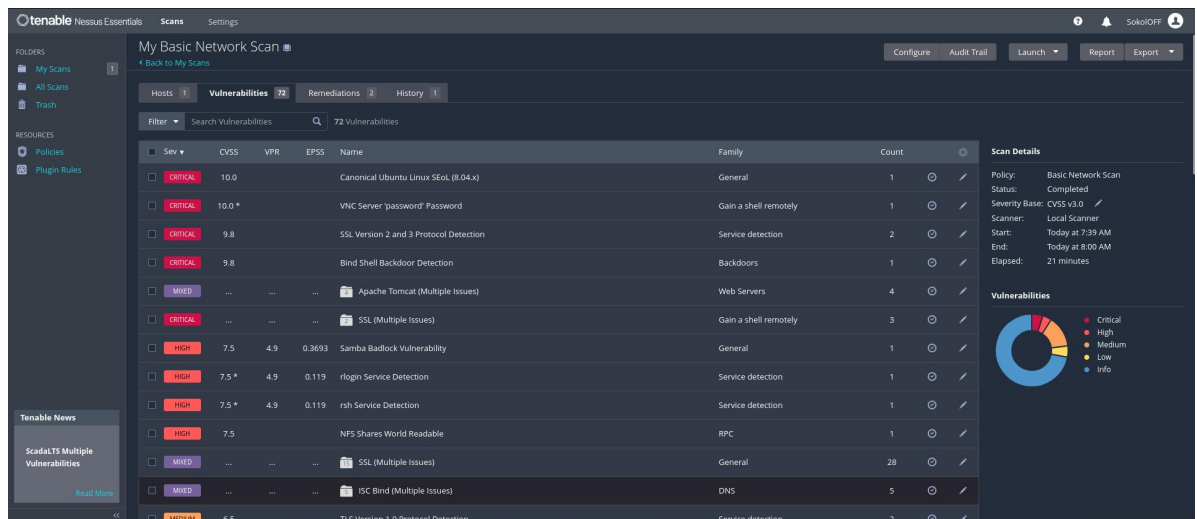


Рисунок 3 — общий результат сканирования

3 ГЛУБОКИЙ АНАЛИЗ КЛЮЧЕВЫХ СРАБАТЫВАНИЙ ПЛАГИНОВ

3.1. Срабатывание плагинов Nessus (Проблемы криптографии SSL/TLS).

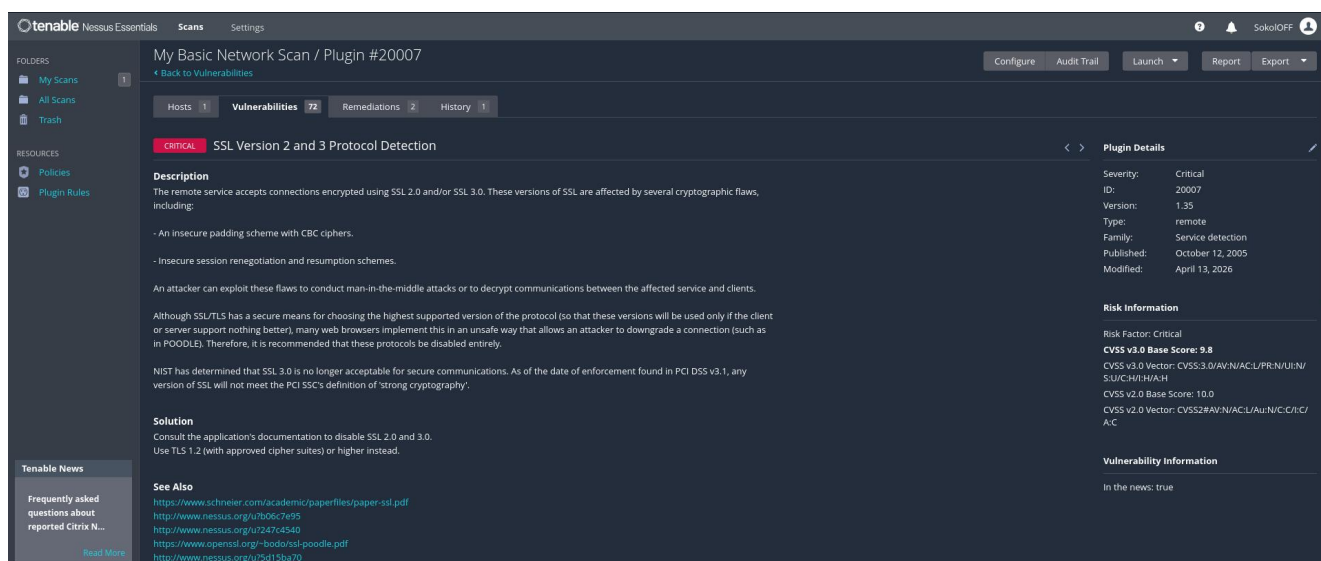


Рисунок 4 — Глубокий анализ проблемы криптографии ssl/tls

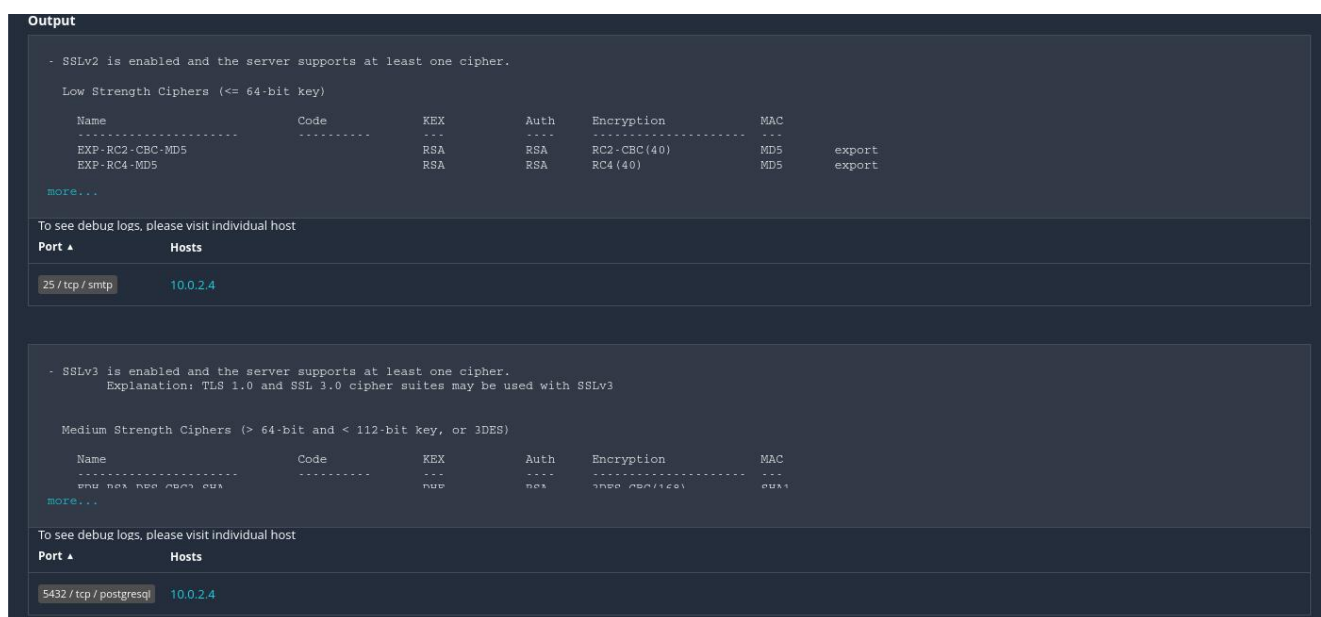


Рисунок 5 — Глубокий анализ проблемы криптографии ssl/tls

- **Название уязвимости:** SSL Version 2 and 3 Protocol Detection
- **Идентификатор плагина (Plugin ID):** 20007
- **Векторы (Порты):** 25 / tcp / smtp (Почтовый сервис) и 5432 / tcp / postgresql
- **Метрика риска: CVSS v3.0 Base Score: 9.8 (КРИТИЧЕСКИЙ)**
- **Описание отчета Nessus:** Плагин обнаружил, что удаленные службы принимают сетевые подключения, зашифрованные с помощью устаревших протоколов SSLv2 и SSLv3. Сканер зафиксировал поддержку криптографически слабых экспортных шифров (Low/Medium Strength Ciphers <=

64-bit key): EXP-RC2-CBC-MD5, EXP-RC4-MD5, что делает сессии уязвимыми к атакам класса POODLE.

- **Бизнес-риск:** Злоумышленник в локальной сети методом Man-in-the-Middle может принудительно снизить версию шифрования, получить возможность перехвата и анализа защищаемого трафика при выполнении соответствующих условий атаки.
- **Решение сканера (Solution):** Изучить конфигурацию SMTP-сервера и PostgreSQL. Полностью отключить поддержку SSLv2 и SSLv3. Разрешить установление сессий только по современным протоколам TLS 1.2 / TLS 1.3 с сильными наборами шифров.

3.2. Срабатывание плагинов по критическим дефектам ОС (Системные бэкдоры)

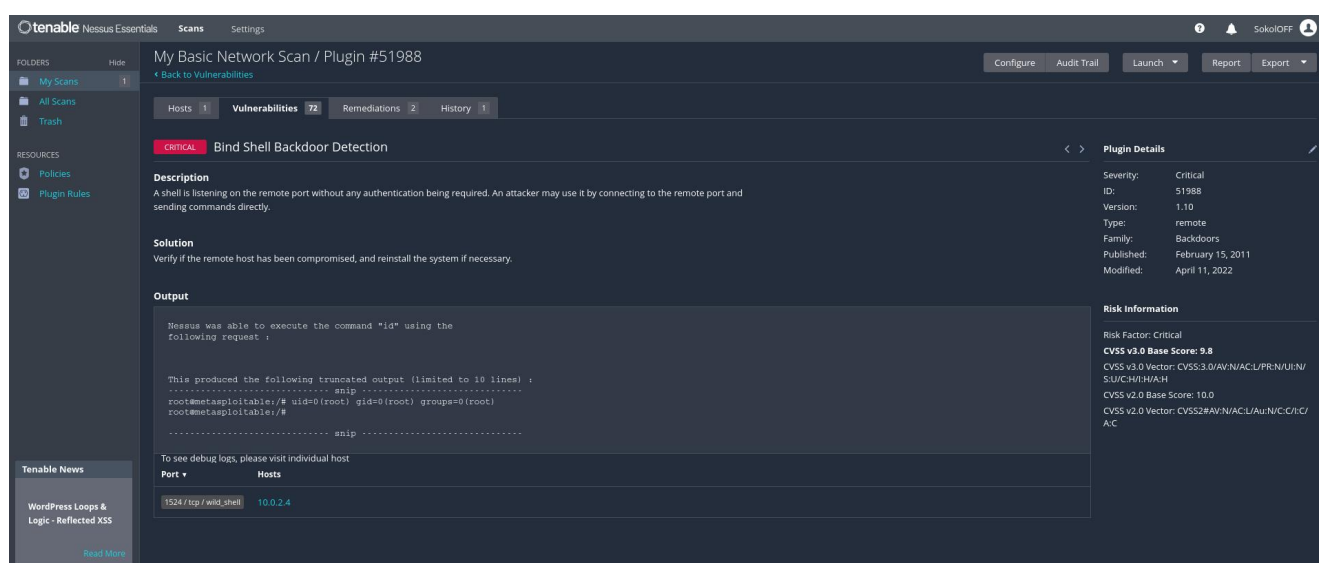


Рисунок 6 — Глубокий анализ bind shell backdoor detection

- **Название уязвимости:** Bind Shell Backdoor Detection
- **Идентификатор плагина (Plugin ID):** 51988
- **Вектор (Порт):** 1524 / tcp / bind_shell
- **Метрика риска: CVSS v3.0 Base Score: 9.8 (КРИТИЧЕСКИЙ)**
- **Описание отчета Nessus:** Специализированный плагин бэкдоров обнаружил на порту 1524 командную оболочку, которая отвечает на запросы без прохождения процедуры аутентификации.
- **Техническое доказательство (Output сканера):** Nessus успешно подключился к порту и отправил системный запрос id. Целевая Metasploitable 2 вернула ответ, подтверждающий максимальные привилегии:

```
root@metasploitable:/# id
uid=0(root) gid=0(root) groups=0(root)
```
- **Бизнес-риск:** Максимальный. Любой пользователь в сети может удаленно выполнять абсолютно любые команды на сервере с правами суперадминистратора, минуя логи и системы защиты.

4 ПРОГРАММА ИСПРАВЛЕНИЙ НА ОСНОВЕ РЕКОМЕНДАЦИЙ NESSUS

Для устранения зафиксированных рисков безопасности владельцам системы предписано выполнить рекомендации из блоков **Solution** отчетов Nessus:

Модернизация СУБД PostgreSQL (postgresql.conf): Ограничить параметры шифрования, прописав строгий запрет на устаревшие протоколы и слабые шифры:

```
ssl = on  
ssl_ciphers = 'HIGH:!aNULL:!MD5:!3DES'  
ssl_protocols = 'TLSv1.2, TLSv1.3'
```

Экстренная блокировка портов: Настроить внутренний фаервол (iptables) или сетевой экран VirtualBox для полной изоляции портов 1524 (бэкдор) и 5900 (небезопасный VNC со стандартным паролем password).

Жизненный цикл ПО (Lifecycle Management): Так как плагин *Canonical Ubuntu Linux SEoL* указывает на полное прекращение поддержки операционной системы, требуется плановый перенос (миграция) всех сервисов на современную платформу (например, Ubuntu LTS 24.04).

ЗАКЛЮЧЕНИЕ

В ходе выполнения проекта был успешно освоен промышленный инструмент **Tenable Nessus Essentials**. Практическая работа доказала важность регулярного автоматизированного сканирования: инструмент позволил за один цикл выявить 72 уязвимых элемента на исследуемом хосте, точно приоритизировать угрозы по шкале CVSS и выдать готовые инструкции (Remediation) для технического персонала.

Соколов Руслан | Sokol[OFF]